

CISSP Printable Practice Exam 27 - Domain 3 - Security Architecture and Engineering

Practice Exam 04 - Domain 3

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP4-040)

Scenario: A consulting firm serves several direct competitors. Once a consultant accesses confidential information for one client, the platform must prevent that consultant from accessing confidential information belonging to competing clients while still allowing access to public industry data.

Which formal security model MOST directly supports this requirement?

- A. Brewer-Nash
- B. Bell-LaPadula
- C. Biba
- D. Clark-Wilson

Question 2 (CISSP4-041)

Scenario: A secure workflow begins in an approved state, but an error-recovery path can move a transaction directly from pending review to completed without evaluating mandatory authorization rules.

From a state-machine security perspective, what is the PRIMARY design defect?

- A. The workflow contains more than one operational state.
- B. The recovery path records a different timestamp than the normal path.
- C. A permitted transition can move the system into a state that violates a security invariant.
- D. The completed state cannot return automatically to the pending state.

Question 3 (CISSP4-042)

Scenario: A report-generation service reads approved records from one database view and writes finished reports to one storage location. It currently runs using an infrastructure administrator identity with broad access across the environment.

Which redesign BEST implements least privilege?

- A. Retain the administrator identity but rotate its password more frequently.
- B. Use the administrator identity only during business hours and disable it overnight.
- C. Share the administrator identity with a backup service to improve availability.
- D. Assign a dedicated identity limited to the required database read and report-storage write operations.

Question 4 (CISSP4-043)

Scenario: A public benefits application relies on one application gateway to block malicious requests. If the gateway is bypassed, the backend accepts any syntactically valid request and the database identity can modify every application table.

Which redesign BEST applies defense in depth?

- A. Add a second identical gateway rule set but leave backend authorization and database privileges unchanged.
- B. Retain the gateway while adding backend authorization, strict input handling, narrowly scoped database access, and monitoring at each boundary.
- C. Increase gateway logging capacity and continue trusting all requests that reach the backend.

D. Hide the backend address from documentation and preserve the existing database identity.

Question 5 (CISSP4-044)

Scenario: A company uses a managed analytics platform whose operator is responsible for infrastructure hardening and backup execution. The company remains accountable for protecting its information and cannot rely only on the operator's verbal assurances.

Which TWO actions BEST implement trust but verify? Select 2 of the 5 options below.

- A. Assume that advertised platform features are enabled for every tenant configuration.
- B. Transfer all risk ownership to the operator because the infrastructure is managed externally.
- C. Define control responsibilities and obtain appropriate evidence that the operator performs its assigned controls.
- D. Disable customer-side logging so the operator remains the only source of security information.
- E. Independently monitor customer-visible configurations, access, backup results, and exceptions against requirements.

Question 6 (CISSP4-045)

Scenario: An online reservation service routes public traffic through a protective application gateway, but the backend servers also have public addresses and accept direct requests that never pass through the gateway.

Which architectural correction MOST directly closes the bypass?

- A. Increase the gateway's processing capacity while leaving the backend publicly reachable.
- B. Remove direct public reachability and allow backend requests only from authorized gateway paths with authenticated service communication.
- C. Add a banner to the backend stating that direct connections are prohibited.
- D. Retain public backend access but use less descriptive server hostnames.

Question 7 (CISSP4-046)

Scenario: A database server encrypts data files, but the only copy of the master encryption key is stored in a readable configuration file on the same server under the same administrative control.

Which redesign BEST reduces the common-mode exposure?

- A. Rename the key file and move it to another directory on the same server.
- B. Compress the encrypted data files before placing them on storage media.
- C. Use a longer configuration-file name and restrict access to database users only.
- D. Protect the master key in a separate controlled key-management boundary and authorize database use without exposing raw key material.

Question 8 (CISSP4-047)

Scenario: A property-management company is deploying thousands of smart meters. Every meter arrives with the same factory administrator password, and installers plan to leave that credential active after connecting devices to the management platform.

Which onboarding architecture is MOST appropriate?

- A. Give each device a unique identity, authenticate enrollment, replace or disable factory credentials, and bind the device to its authorized owner.

- B. Keep the shared credential but change the management portal's display name after deployment.
- C. Publish the factory password only to installers and assume it will remain confidential.
- D. Place meters in multiple buildings while retaining the same credential to simplify support.

Question 9 (CISSP4-048)

Scenario: A distributed payment workflow retries messages when acknowledgments are delayed. An attacker can replay a previously valid request, and the receiving service currently creates a new transfer each time the message arrives.

Which architectural control BEST addresses this risk?

- A. Increase the message retry interval while allowing every received request to create a transfer.
- B. Encrypt the message queue but do not track previously processed requests.
- C. Authenticate requests and enforce idempotent processing using unique transaction identifiers, freshness checks, and recorded completion state.
- D. Add more receiving-service instances and distribute replayed requests among them.

Question 10 (CISSP4-049)

Scenario: An event-driven document service uses many short-lived functions. Every function shares one broad execution role, and any account in the environment can create events that invoke sensitive processing functions.

Which TWO changes BEST reduce the architectural exposure? Select 2 of the 5 options below.

- A. Increase function memory allocation while retaining the shared execution role.
- B. Assign each function a narrowly scoped execution identity based on its required resources and actions.
- C. Store additional event copies so failed processing can be retried more often.
- D. Restrict and authenticate permitted event sources before sensitive functions can be invoked.
- E. Use a longer common role name so accidental selection becomes less likely.

Question 11 (CISSP4-050)

Scenario: An application accepts any certificate signed by a trusted root. It does not verify the requested service identity or whether the certificate is authorized for the intended purpose.

What validation should the architect require?

- A. Verify only that the certificate contains a public key of the expected length.
- B. Accept the certificate when its subject field contains any organization name.
- C. Validate the trust chain, validity and revocation status, permitted key usage, and the certificate identity expected for the service.
- D. Store a local copy of the certificate without evaluating its identity or purpose.

Question 12 (CISSP4-051)

Scenario: A multi-tenant archive encrypts every customer's files directly with one long-lived symmetric key. Management wants to rotate protection without re-encrypting all file contents and to limit the impact of one tenant-key compromise.

Which design BEST meets these goals?

- A. Use separate data-encryption keys by appropriate scope and wrap them with

- controlled key-encryption keys that can be rotated independently.
- B. Keep one long-lived content key but rename it for each tenant in application metadata.
- C. Hash the common encryption key and publish the hash with every archived file.
- D. Duplicate the common key across additional servers so it remains available during maintenance.

Question 13 (CISSP4-052)

Scenario: Two internal systems already share a protected symmetric secret. The receiving system must detect message modification and verify that a party holding the shared secret generated the message. Confidentiality is not required.

Which mechanism is MOST appropriate?

- A. A plain checksum transmitted with the message
- B. An unkeyed cryptographic hash stored beside the message
- C. Reversible encoding using a format known only to the two systems
- D. A hash-based message authentication code computed with the shared secret

Question 14 (CISSP4-053)

An attacker possesses a collection of encrypted messages but has no corresponding plaintext, encryption key, or ability to request chosen encryptions or decryptions. Which attack condition is described?

- A. Known-plaintext
- B. Ciphertext-only
- C. Chosen-plaintext
- D. Side-channel

Question 15 (CISSP4-054)

Scenario: An embedded controller generates encryption keys immediately after startup using only its current clock value. Devices powered on together frequently create identical keys.

Which correction BEST addresses the cryptographic weakness?

- A. Use an approved cryptographically secure random generator seeded with sufficient unpredictable entropy and monitor for generator failure.
- B. Format the clock value in a longer text string before using it as the key.
- C. Generate keys at the same scheduled time so administrators can reproduce them if needed.
- D. Encode duplicate keys before storing them on each controller.

Question 16 (CISSP4-055)

Scenario: A small data-processing site has dense shrubs beside ground-floor windows and tall landscaping that conceals portions of the pedestrian approach from guards and cameras.

Which redesign BEST applies security-conscious environmental design?

- A. Add taller opaque vegetation along the entire building to discourage observation from outside.
- B. Move cameras indoors and retain the concealed exterior approach.
- C. Create additional informal paths through the landscaping so pedestrians can choose their own route.
- D. Use low or appropriately spaced landscaping, preserve clear sight lines, and channel visitors toward monitored entrances.

Question 17 (CISSP4-056)

Scenario: A hardware repair room experiences unexplained component failures during dry weather. Technicians work on synthetic carpet, humidity falls below the approved range, and no grounded work surfaces or wrist straps are provided.

Which corrective design is MOST appropriate?

- A. Increase room temperature and continue using the existing carpet and work surfaces.
- B. Store components in ordinary plastic bags and require technicians to touch a wall before repairs.
- C. Install grounded static-dissipative surfaces, use appropriate personal grounding and packaging, and maintain humidity within the approved range.
- D. Disable environmental alarms during dry weather to reduce unnecessary work interruptions.

Question 18 (CISSP4-057)

Scenario: A financial processing facility receives both primary communications circuits through one exposed conduit and places the carrier demarcation panels in an unlocked shared maintenance closet.

Which TWO changes BEST reduce the identified risks? Select 2 of the 5 options below.

- A. Use physically diverse service routes where justified so one local event is less likely to sever every circuit.
- B. Label the shared conduit more clearly while retaining both circuits in the same exposed path.
- C. Move the demarcation panels into the public lobby so carrier technicians can reach them easily.
- D. Terminate both circuits on one unprotected panel to simplify maintenance.
- E. Place demarcation equipment in a restricted, monitored area with controlled maintenance access.

Question 19 (CISSP4-058)

Scenario: A museum's emergency exits allow immediate evacuation as required, but intruders have used the same doors to enter a restricted archive when staff temporarily defeated the door contacts to stop nuisance alarms.

Which design is MOST appropriate?

- A. Lock the emergency exits from both directions until a security officer approves each evacuation.
- B. Preserve code-compliant free egress while using monitored door hardware, reliable alarms, exterior-entry protection, and a defined response process.
- C. Disable all exit alarms during public hours and rely on staff observation.
- D. Replace emergency exits with access-controlled revolving doors.

Question 20 (CISSP4-059)

Scenario: During a two-week renovation, contractors need equipment access through a normally alarmed service door. Previous projects left temporary access badges and alarm bypasses active after work ended.

Which approach BEST protects the facility throughout the maintenance period?

- A. Disable the service-door alarm for the entire project and depend on contractors to report unusual activity.
- B. Issue permanent badges to the contractor supervisor so future projects require less setup.
- C. Use approved time-limited access and documented bypasses, add compensating

monitoring, and verify restoration and credential revocation at closeout.

D. Leave the normal alarm enabled but provide all contractors with the shared employee door code.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP4-040) - Correct: A

Brewer-Nash, also called the Chinese Wall model, dynamically restricts access based on information previously accessed to prevent conflicts of interest. Bell-LaPadula emphasizes confidentiality labels, Biba emphasizes integrity levels, and Clark-Wilson protects commercial integrity through constrained transactions and separation of duties.

Question 2 (CISSP4-041) - Correct: C

A secure state-machine design requires every allowed transition to preserve the system's defined security properties. Bypassing mandatory authorization creates an insecure reachable state. Multiple states and different timestamps are not inherently defects, and inability to reverse a completed transaction does not explain the authorization failure.

Question 3 (CISSP4-042) - Correct: D

A dedicated identity with narrowly scoped permissions limits both routine authority and the impact of service compromise. Password rotation does not reduce authorization scope. Time restrictions leave excessive privileges during operation, and sharing the identity increases exposure and weakens accountability.

Question 4 (CISSP4-043) - Correct: B

Complementary enforcement at the gateway, application, database, and monitoring layers prevents one failed or bypassed control from exposing the entire system. A duplicate rule set may repeat the same weakness. More gateway logging remains dependent on one enforcement point, and hiding an address is not a reliable security boundary.

Question 5 (CISSP4-044) - Correct: C, E

Clear responsibility mapping establishes what must be verified, while independent monitoring and suitable evidence test whether controls operate as expected. Feature claims do not prove tenant configuration. Accountability cannot be transferred entirely, and disabling customer visibility removes an important verification capability.

Question 6 (CISSP4-045) - Correct: B

Restricting backend reachability to authenticated gateway paths makes the intended control boundary enforceable. More gateway capacity does not affect direct access. A warning banner is administrative, and obscure hostnames do not prevent discovery or connection.

Question 7 (CISSP4-046) - Correct: D

A separate controlled key-management boundary prevents compromise of the database host from automatically yielding both ciphertext and the master key. Renaming or relocating the file on the same host preserves the shared failure domain. Compression and filename length do not protect keys.

Question 8 (CISSP4-047) - Correct: A

Unique device identity, authenticated enrollment, removal of shared defaults, and ownership binding prevent compromise of one credential from exposing the full fleet. A portal name has no authentication value. Limiting initial distribution cannot make a fleet-wide shared secret safe, and physical distribution across buildings does not reduce credential reuse risk.

Question 9 (CISSP4-048) - Correct: C

Authenticated requests combined with unique identifiers, freshness validation, and durable completion state allow safe retries while rejecting or neutralizing replays. Longer

intervals do not prevent duplicates. Queue encryption protects confidentiality but not repeated valid messages, and additional instances can increase concurrency without establishing transaction uniqueness.

Question 10 (CISSP4-049) - Correct: B, D

Function-specific least privilege limits the effect of compromise, while authenticated and restricted triggers prevent unauthorized invocation. Memory size and event-copy count concern capacity or reliability rather than authorization. A longer role name does not reduce the role's excessive permissions.

Question 11 (CISSP4-050) - Correct: C

A valid signature chain alone does not prove that a certificate represents the intended service or is authorized for the requested use. Complete validation includes chain construction, time validity, revocation status, key-usage constraints, and expected identity. Key length, a generic organization name, or local storage cannot substitute for those checks.

Question 12 (CISSP4-051) - Correct: A

Scoped data-encryption keys reduce compromise impact, while wrapping them with separately managed key-encryption keys supports efficient rotation by rewrapping keys rather than re-encrypting all content. Renaming does not create distinct keys. Publishing a hash adds no protection, and copying the same key expands its exposure.

Question 13 (CISSP4-052) - Correct: D

A hash-based message authentication code uses the shared secret to provide integrity and symmetric origin authentication. A checksum or unkeyed hash can be recomputed by an attacker who changes the message. Reversible encoding is not a cryptographic integrity control.

Question 14 (CISSP4-053) - Correct: B

A ciphertext-only attack begins with encrypted messages and no matching plaintext or oracle access. Known-plaintext includes some matching plaintext and ciphertext. Chosen-plaintext involves obtaining encryptions of selected inputs, while side-channel attacks exploit implementation leakage such as timing or power use.

Question 15 (CISSP4-054) - Correct: A

Cryptographic keys require sufficient unpredictable entropy from an approved generator; health checks help identify a failed random source. A longer representation does not add entropy. Scheduled generation increases predictability, and encoding identical keys does not make them independent or random.

Question 16 (CISSP4-055) - Correct: D

Clear sight lines and defined movement toward monitored entrances increase natural surveillance and reduce concealment. Taller opaque vegetation creates hiding places. Indoor-only cameras do not restore exterior visibility, and informal paths weaken controlled access and make observation more difficult.

Question 17 (CISSP4-056) - Correct: C

Static-dissipative grounded surfaces, personal grounding, protective packaging, and controlled humidity address the generation and discharge of static electricity. Temperature alone does not solve the problem. Ordinary plastic can generate static, touching a wall is unreliable, and disabling alarms conceals rather than reduces risk.

Question 18 (CISSP4-057) - Correct: A, E

Physically diverse routes reduce common-path failure, while restricted and monitored demarcation space prevents casual tampering and records authorized access. Labels do not create route diversity. Public placement increases exposure, and a single unprotected panel preserves a common failure and attack point.

Question 19 (CISSP4-058) - Correct: B

Life safety requires code-compliant egress, while monitored hardware, protected exterior entry, dependable alarms, and response procedures address unauthorized use. Locking evacuation routes or using unsuitable barriers can endanger occupants. Disabling alarms removes detection rather than correcting nuisance-alarm causes.

Question 20 (CISSP4-059) - Correct: C

Time-limited authorization, documented exceptions, compensating monitoring, and formal closeout control the temporary need and ensure normal protection is restored. A project-long unmonitored bypass creates exposure. Permanent or shared credentials outlive the work and weaken accountability.